REQUEST TO QUOTE

Dear whom it may concern,

We are writing to request a quote for the following services: GDPR Audit

1. Background:

Ryde Town Council invites quotations from suitably qualified organisations to carry out an independent audit of its compliance with data protection law, and to recommend the improvements needed.

Ryde Town Council is the largest town council on the Isle of Wight, it employs 29 staff, is served by 16 elected councillors, and delivers a wide range of service that include; events, grants, allotments, marina berthing, community support service, youth service.

In delivering these services the Council processes personal data about residents, service users, councillors, staff, volunteers, contractors and members of the public who contact it. The Council wishes to have clear, independent assurance that this processing complies with:

- the UK General Data Protection Regulation (UK GDPR)
- the Data Protection Act 2018
- the Data (Use and Access) Act 2025, as its provisions come into force
- the Privacy and Electronic Communications Regulations 2003 (PECR)
- relevant guidance from the Information Commissioner's Office (ICO)

The audit should also take account of related obligations, such as the Freedom of Information Act 2000 and records retention guidance for local councils, where they affect how personal data is handled.

2. Purpose & Objectives

The audit will tell the Council where it stands against data protection law today and give it a prioritised, practical plan to close any gaps. Its objectives are to:

I. Map what personal data the Council holds, where it comes from, where it is stored, who it is shared with and how long it is kept.
II. Assess compliance with the UK GDPR principles and the Council's accountability obligations.
III. Identify risks to individuals and to the Council, including the risk of a personal data breach, complaint or ICO enforcement.
IV. Review the adequacy of the Council's existing policies, notices, procedures, contracts and training.
V. Provide clear, proportionate recommendations suited to the size and resources of a town council.

VI. Leave the Council with core documentation it can maintain itself, such as a Record of Processing Activities (ROPA).

3. Scope of work

3.1 Data mapping and lawful basis

- Carry out a data inventory and information flow mapping across all Council functions.
- Confirm the lawful basis for each processing activity, and the additional condition for any special category or criminal offence data.
- Review where consent is relied on, and whether it meets UK GDPR standards.
- Produce or update the Record of Processing Activities (Article 30).

3.2 Governance and accountability

- Review the Council's data protection policy and related policies (information security, retention, acceptable use, CCTV, remote working, bring your own device).
- Review roles and responsibilities, including the Council's data protection officer (DPO) arrangements and whether they are appropriate.
- Check that data protection is properly reported to councillors and reflected in the Council's risk register.
- Assess the use of Data Protection Impact Assessments (DPIAs) and whether any are outstanding.

3.3 Transparency

- Review all privacy notices (website, staff, councillors, job applicants, service users, CCTV, events) for accuracy and completeness.
- Review cookie and website tracking compliance under PECR.
- Review the lawful use of email, newsletters and other electronic marketing.

3.4 Individuals' rights

- Review procedures for subject access requests and the other rights (rectification, erasure, restriction, objection, portability).
- Test how a request is recognised, logged and answered within statutory time limits.
- Review the handling of data protection complaints.

3.5 Security of personal data

- Review technical and organisational security measures, including access controls, passwords and multi-factor authentication, encryption, backups and device management.
- Review the security of email and cloud services, including the use of personal email accounts or devices by councillors and staff.
- Review physical security and the storage and disposal of paper records.

3.6 Councillors

- Review how councillors handle personal data in their Council role, including casework and constituent correspondence.
- Advise on councillor email accounts, devices and any need for councillors to register with the ICO.

3.7 Third parties and data sharing

- Identify all processors and suppliers handling personal data on the Council's behalf (e.g. IT support, payroll, cloud software, booking systems, CCTV providers).
- Review contracts for Article 28 compliant data processing terms.
- Review data sharing with other bodies, such as the Isle of Wight Council, the police and community partners.
- Identify any international transfers of personal data and the safeguards in place.

3.8 Retention and disposal

- Review the retention schedule against legal requirements and sector guidance for local councils.
- Assess whether records are actually being disposed of in line with the schedule

3.9 Breach management

- Review the personal data breach procedure, breach log and the process for reporting to the ICO within 72 hours.
- Review any past incidents and how they were handled.

3.10 Training & awareness

- Assess the data protection training given to staff and councillors, and its frequency.
- Gauge awareness through short interviews or a questionnaire.

3.11 CCTV and surveillance

- Where the Council operates or shares CCTV, review compliance with the UK GDPR and the Surveillance Camera Code of Practice, including signage, DPIAs, access and retention.

Method

The Council expects the audit to combine document review, interviews with key staff and a sample of councillors, and observation of systems and working practices. At least part of the fieldwork should take place on site at the Council's offices in Ryde. Suppliers should describe their proposed method in their quotation.

4. Deliverables

The supplier will provide the following, in editable electronic format (Word and Excel or equivalent), which the Council will own outright.

Deliverable	Description
Inception meeting and audit plan	A short plan confirming method, interviewees, documents required and dates, agreed with the Town Clerk and RFO before fieldwork starts.
Draft audit report	Findings against each scope area, with a RAG (red/amber/green) compliance rating and the evidence behind each finding.
Prioritised action plan	Each recommendation with a risk rating, suggested owner, estimated effort or cost, and a target timescale.
Record of Processing Activities	A completed ROPA covering all processing activities identified.
Information asset register and data flow map	A register of information assets and a map of how personal data flows into, around and out of the Council.
Final audit report	Updated after the Council's comments on the draft, with a plain-English executive summary suitable for publication to councillors.
Presentation to councillors	A presentation of key findings to the relevant committee or Full Council, with time for questions.

5. Supplier requirements

Suppliers must show they have the expertise to audit a small public body proportionately. The Council requires:

- Demonstrable experience of data protection audits for local councils, other local authorities or comparable public sector bodies.
- Named auditors holding a recognised data protection qualification, such as BCS Practitioner Certificate in Data Protection, PC.dp, CIPP/E, or equivalent.
- Up-to-date knowledge of the UK GDPR, the Data Protection Act 2018, the Data (Use and Access) Act 2025 and current ICO guidance.
- Familiarity with how town and parish councils operate, including the role of councillors and the Town Clerk.
- Independence: the supplier must declare any existing relationship with the Council, its councillors or its IT providers that could create a conflict of interest.
- Professional indemnity insurance of at least £5,000,000 and public liability insurance of at least £5,000,000.
- Registration with the ICO as a data controller, with its own data protection and information security arrangements.
- Two references from clients for whom similar work has been completed in the last three years, ideally including a town or parish council.

6. Timetable

The Council aims to appoint a supplier in November 2026 and receive the final report by the end of February 2027. The dates below are indicative and may change

Stage	Date
Request for quotation issued	Oct 12, 2026
Deadline for clarification questions	Oct 26, 2026
Deadline for quotations	Nov 2, 2026 (12 noon)
Evaluation and any clarification interviews	Week commencing Nov 9, 2026
Appointment approved by Council	Nov 24, 2026
Inception meeting	By Dec 11, 2026
Fieldwork	December 2026/January 2027
Draft report to Clerk/RFO	Jan 25, 2027
Final report and presentation	Feb 2, 2027

Suppliers should state in their quotation whether they can meet this timetable and, if not, propose an alternative.

7. Payment Terms:

- Payment Method: Bank Transfer
- Payment Terms:
    - 20% Upon Appointment
    - 20% Prior to Fieldwork commencement
    - 30% Upon receipt of Draft Report
    - 30% After final report and presentation

5. Validity of Quote:

- Please confirm that your quote will remain valid for a minimum of 60 days from the date of your response.

6. Additional Information:

- **Data handling during the audit**: the supplier must access personal data only as needed, keep it securely, not remove it from Council premises or systems without agreement, and securely delete any copies at the end of the contract.
- **Confidentiality**: all information obtained during the audit is confidential and must not be disclosed to third parties without the Council's written consent.
- **Ownership**: all reports and documents produced become the property of Ryde Town Council, which may share or publish them as it sees fit.
- **Contract**: the Council will issue a purchase order and a short contract or letter of engagement setting out the scope, fee and terms.

- **Procurement**: this exercise is carried out under the Council's Financial Regulations and Standing Orders.
- **Freedom of Information**: the Council is subject to the Freedom of Information Act 2000. Suppliers should mark any part of their quotation they consider commercially sensitive, though the Council cannot guarantee it will be withheld.

We look forward to receiving your quote by Noon on November 2nd 2026. Should you have any questions or require further information, please do not hesitate to contact us.

Thank you for your prompt attention to this request.

Yours sincerely,

Tara Bloomfield

Responsible Financial Officer

01983 811105

Tara.bloomfield@rydetowncouncil.gov.uk